



NOTE DE CADRAGE

Projet PING × ReachFive

*Banc d'essai adversarial pour l'évaluation
des mécanismes de détection CIAM*

Groupe	P25
Membres	Florian Ngo Hugo Tissot Mohamed Reda Zouine Ahmed Messaoui
Client	ReachFive
Date	05/05/2026

Sommaire

1. Contexte
2. Enjeu
3. Objectifs du projet
4. Approche et architecture
5. Méthodologie
6. Temporalité du projet
7. Indicateurs de performance
8. Organisation et équipe
9. Contraintes et risques
10. Livrables attendus

1. Contexte

Les plateformes de gestion d'identités clients (CIAM, Customer Identity and Access Management) occupent une place centrale dans les infrastructures numériques modernes. Elles assurent l'authentification des utilisateurs et protègent l'accès à des services critiques dans des domaines tels que le e-commerce, la banque ou les services publics.

Ces plateformes sont aujourd'hui des cibles privilégiées d'attaques automatisées, notamment :

- le credential stuffing
- le brute force adaptatif
- les attaques distribuées et low-and-slow

L'évolution des techniques d'attaque, en particulier via l'usage d'outils automatisés et d'intelligence artificielle, permet aux attaquants de contourner de plus en plus efficacement les mécanismes de détection traditionnels.

Les systèmes actuels reposent encore largement sur des heuristiques globales, telles que le blocage basé sur l'adresse IP. Bien que simples à mettre en œuvre, ces approches présentent des limites importantes :

- manque de granularité
- difficulté à détecter des attaques distribuées
- taux de faux positifs élevé (utilisateurs légitimes derrière des proxies)

Dans ce contexte, il devient nécessaire de développer des approches plus fines, capables d'analyser chaque requête dans son contexte afin de détecter des comportements frauduleux tout en préservant l'expérience utilisateur.

2. Enjeu

Faire évoluer la détection des comportements frauduleux à l'authentification d'une logique globale, fondée sur des règles statiques ou l'adresse IP, vers une analyse fine et contextuelle des requêtes — sans dégrader l'expérience des utilisateurs légitimes.

Le compromis entre sécurité et friction utilisateur est au cœur du projet : un mécanisme trop laxiste laisse passer les attaques, un mécanisme trop strict pénalise les utilisateurs. L'enjeu consiste à identifier ce point d'équilibre et à le maintenir face à des attaques adaptatives.

3. Objectifs du projet

3.1 Objectifs principaux

- Évaluer la robustesse des mécanismes de détection face à des attaques adaptatives

- Identifier les limites des stratégies de défense existantes
- Réduire le taux de faux positifs
- Quantifier le compromis entre sécurité et friction utilisateur

3.2 Objectifs techniques

- Simuler des scénarios d'attaque réalistes dans un environnement contrôlé
- Exploiter des logs de type User Events (ReachFive)
- Concevoir un moteur de détection basé sur des règles simples et des seuils adaptatifs
- Mettre en place un système de réponse automatisé (throttling, blocage, step-up)
- Développer un module d'évaluation basé sur des indicateurs mesurables

4. Approche et architecture

4.1 Vision adversariale

Le projet vise à construire un banc d'essai adversarial permettant d'évaluer la robustesse des mécanismes de détection d'une plateforme CIAM face à des attaques adaptatives. Ce dispositif repose sur une architecture Red Team / Blue Team, dans laquelle les interactions entre attaquant et défenseur sont partiellement assistées par des modèles de langage (LLM).

- **Red Team** : génère des scénarios d'attaque réalistes, variés et adaptatifs pour éprouver les défenses.
- **Blue Team** : analyse les comportements observés et adapte les mécanismes de détection et de réponse en temps réel.

4.2 Rôle des LLM

Les LLM sont utilisés comme outils d'orchestration et d'exploration. Ils permettent de générer des scénarios d'attaque diversifiés, d'analyser des patterns complexes et de proposer des stratégies de réponse.

- **Agilité** : génération automatique de scénarios complexes et aide à la décision pour la Blue Team sans dépendance externe.
- **Souveraineté** : utilisation de modèles locaux (Llama, Mistral) pour garantir qu'aucune donnée de log ou pattern de défense ne quitte l'infrastructure.

4.3 Architecture technique

Le système s'articule autour des composants suivants :

- un simulateur d'authentification (sans interface utilisateur complexe)
- un injecteur de trafic (Red Team) générant des attaques
- un système de logs structurés inspiré des User Events
- un module de feature engineering

- un moteur de détection et de décision (Blue Team)
- un module d'évaluation et de visualisation

Flux du banc d'essai

RED TEAM	BANC D'ESSAI	LOGS / USER EVENTS	BLUE TEAM	RÉPONSE
Injecteur d'attaques	Simulateur CIAM	Flux structuré	Moteur de détection	Throttle / block / step-up

4.4 Données exploitées

Les données utilisées sont des logs d'événements d'authentification, comprenant notamment :

- timestamp
- user_id
- adresse IP (hachée)
- type d'événement (login, échec, succès)
- device / user_agent
- résultat de la tentative

Ces données permettent d'analyser les comportements à différentes échelles : requête, utilisateur, système global.

5. Méthodologie

Le projet est structuré en cinq étapes successives, avec une logique de co-construction permanente entre la Red Team (attaque) et la Blue Team (défense). Chaque étape produit un livrable intermédiaire qui alimente la suivante.

Étape 1 — Mise en place du banc de test

Objectif : construire un environnement de simulation fonctionnel reposant sur un véritable site web d'authentification. Ce choix d'aller au-delà d'un simple simulateur en ligne de commande est stratégique : il permet de capter une richesse bien plus grande de métriques utilisateur (user_agent, device fingerprint, timing des frappes, comportement de navigation, géolocalisation IP, headers HTTP, cookies de session, etc.) qui seront exploitables par le moteur de détection en aval.

- **Blue Team** : développer un véritable site web d'authentification (frontend + backend), définir le format des logs étendus (User Events ReachFive), implémenter le pipeline de collecte, ajouter une première détection simple.
- **Red Team** : implémenter une attaque basique (brute force) et générer du trafic pour alimenter les logs.

- **Livable** : site web d'authentification opérationnel, logs riches et exploitables, première détection validée.

Étape 2 — Génération d'attaques et premiers contournements

Objectif : enrichir les scénarios et tester les limites.

- **Red Team** : implémenter plusieurs types d'attaques (credential stuffing, distribuées, low-and-slow), utiliser les LLM pour générer des variantes et ajuster les paramètres (fréquence, jitter, IP).
- **Blue Team** : analyser les logs générés, identifier les patterns d'attaque, évaluer les limites des règles existantes et ajuster les règles simples.
- **Livable** : ensemble de scénarios réalistes, identification des failles principales.

Étape 3 — Renforcement de la détection

Objectif : construire une détection robuste et contextuelle.

- **Blue Team** : construire des features comportementales (fréquence, diversité IP/utilisateurs, taux d'échec), mettre en place des seuils adaptatifs (quantiles glissants, règles dynamiques) et utiliser les LLM pour suggérer de nouvelles stratégies de détection.
- **Red Team** : adapter les attaques pour contourner les nouveaux seuils, règles temporelles et détection multi-critères.
- **Livable** : système de détection amélioré, boucle adversariale active.

Étape 4 — Système de réponse automatique

Objectif : déclencher des actions adaptées au type d'attaque détecté.

- **Blue Team** : implémenter les mécanismes de réponse (throttle, blocage, step-up authentication), associer les types d'attaques détectées à des réponses adaptées (ex : brute force → block, low-and-slow → throttle), et s'appuyer sur le LLM pour suggérer la meilleure action selon le contexte.
- **Red Team** : tester si ces réponses sont efficaces ou contournables, exploiter les limites ou incohérences des décisions prises.
- **Livable** : système de réponse fonctionnel et stratégies de défense par type d'attaque.

Étape 5 — Évaluation et optimisation

Objectif : mesurer la performance et stabiliser le système.

- **Blue Team** : calculer les KPI (taux de détection, faux positifs, contournement), mettre en place un dashboard de suivi, analyser les cas d'échec et proposer des recommandations.
- **Red Team** : lancer des scénarios d'attaque finaux, réaliser des tests de charge et de contournement, valider la robustesse des recommandations.
- **Livable** : évaluation complète, comparaison des stratégies, recommandations opérationnelles.

Logique globale

Le projet repose sur une itération continue selon le schéma : attaque → détection → adaptation. Cette confrontation permanente Red vs Blue permet une amélioration progressive de la robustesse du système.

6. Temporalité du projet

Le projet est découpé en quatre sprints, chacun correspondant à une ou deux étapes méthodologiques. Les jalons sont fixés à des dates précises permettant un suivi rigoureux et une livraison itérative.

6.1 Découpage en sprints

Sprint	Période	Contenu
Sprint 1	18/05 → 22/05	Étape 1 (vrai site web d'authentification + logs enrichis pour la collecte de métriques utilisateur) + début d'implémentation de l'étape 2 (premiers scénarios d'attaque).
Sprint 2	22/05 → 05/06	Fin de l'étape 2 (scénarios d'attaque enrichis par LLM) + implémentation de l'étape 3 (moteur de détection avec règles et seuils adaptatifs).
Sprint 3	05/06 → 12/06	Implémentation de l'étape 4 (système de réponse automatique : throttle, blocage, step-up) + début des tests de fonctionnement global.
Sprint 4	12/06 → mi juin	Développement de l'étape 5 (module d'évaluation + benchmark) et finalisation du projet (rapport, recommandations).

6.2 Récapitulatif des jalons

18/05	Lancement du projet
22/05	Site opérationnel et attaquant en cours d'implémentation
05/06	Défenseur opérationnel et adaptation de l'attaquant
12/06	Adaptation du défenseur et début du benchmark
Mi juin	Rendu final du banc d'essai avec préconisations et résultats

7. Indicateurs de performance

La performance du système est évaluée à l'aide de plusieurs indicateurs complémentaires, permettant d'apprécier à la fois l'efficacité de la détection et son impact sur l'expérience utilisateur.

Indicateur	Définition
Taux de détection	Proportion d'attaques correctement identifiées par le moteur de détection.
Taux de faux positifs	Proportion de comportements légitimes incorrectement classifiés comme malveillants.
Temps moyen avant détection	Délai entre le début d'une attaque et son identification par le système.
Taux de contournement	Proportion d'attaques ayant réussi à passer inaperçues.
Coût côté attaquant	Effort (volume de requêtes, temps, ressources) nécessaire pour réussir une attaque.
Niveau de friction utilisateur	Impact des mécanismes de défense sur l'expérience des utilisateurs légitimes.

8. Organisation et équipe

Le projet est mené par le groupe P25, composé de quatre étudiants. L'équipe est organisée en deux pôles travaillant de manière coordonnée et itérative.

Pôle	Membres	Mission
Red Team	Mohamed Reda Zouine Ahmed Messaoui	Génération des scénarios d'attaque, exploitation des LLM pour produire des variantes adaptatives, tests de robustesse.
Blue Team	Florian Ngo Hugo Tissot	Conception du moteur de détection, mise en place des features et seuils adaptatifs, gestion des réponses automatiques, évaluation.

Les deux pôles travaillent avec :

- un format de données commun (logs structurés)
- des itérations régulières et synchronisées
- des phases de tests croisés à chaque fin de sprint

9. Contraintes et risques

9.1 Contraintes

- Environnement isolé (aucune attaque réelle sur des systèmes en production)
- Données générées par IA ou anonymisées (aucune donnée personnelle réelle)
- Utilisation exclusive de modèles open source (Llama, Mistral) pour garantir la souveraineté

9.2 Risques identifiés

Risque	Mesure de mitigation
Complexité excessive due à l'IA	Maintenir une approche progressive : règles simples d'abord, LLM en complément.
Taux de faux positifs élevé	Mesurer systématiquement les FP et calibrer les seuils via des quantiles glissants.
Dérive vers un outil offensif	Cantonnement strict à un environnement isolé, finalité défensive du projet.
Manque d'interprétabilité	Documenter chaque décision du LLM, conserver une couche de règles explicites.

10. Livrables attendus

10.1 Livrables techniques

- **Site web d'authentification** : véritable site web fonctionnel (frontend + backend) permettant la collecte de métriques utilisateur étendues, avec gestion des logs et base de données associée.
- **Injecteur d'attaques** : module Red Team alimenté par LLM, capable de produire plusieurs types d'attaques.
- **Module de détection et de défense** : moteur Blue Team combinant règles, seuils adaptatifs et LLM. Cœur du projet.
- **Système de réponse** : mécanismes automatiques (throttle, blocage, step-up) déclenchés selon le type d'attaque.
- **Dashboard de suivi** : visualisation des KPI et de l'activité du système.

10.2 Livrables analytiques

- **Analyse des défaillances** : rapport des cas où la détection ou la défense a échoué, avec causes identifiées.
- **Comparaison des stratégies** : rapport comparatif de l'efficacité des différentes approches (règles, adaptatif, LLM).
- **Recommandations opérationnelles** : préconisations concrètes issues des résultats du projet.
- **Banc d'essai** : rapport complet contenant l'ensemble des tests réalisés (concluants ou non) avec les explications nécessaires à leur compréhension.